

fancy

Abstract. Centinela is an open-source protocol and reference engine that produces a cryptographically verifiable record of custody for electoral data published by an official authority, under a threat model in which the authority itself may be the adversary. The design follows the Certificate Transparency lineage: a chained, append-only, tamper-evident log whose integrity any third party can verify without trusting the operator, the authority, or the project author. We give a formal threat model, reduce security to two standard assumptions (collision resistance of SHA-256 and EUF-CMA unforgeability of Ed25519), and prove three theorems: (T1) tamper-evidence of the hash chain, (T2) authenticity via verified operator signatures, and (T3) detectability of silent historical rewrites through an external anchor the adversary does not control. We additionally show that an attempt to blind the witness (a targeted connectivity cut) is recorded as a signed, immutable, non-repudiable event rather than indistinguishable silence. The protocol is country-agnostic, zero-cost to operate, and is concretely realized in the dev-v9 reference implementation; each formal claim is mapped to a verifiable source location in Appendix B.

Resumen (Español). Centinela es un protocolo y motor de referencia, de código abierto, que produce un registro de custodia criptográficamente verificable de los datos electorales publicados por una autoridad oficial, bajo un modelo de amenaza en el que la propia autoridad puede ser el adversario. El diseño sigue la línea de Certificate Transparency: una bitácora encadenada, de solo anexo y a prueba de manipulación, cuya integridad cualquier tercero puede verificar sin confiar en el operador, en la autoridad ni en el autor del proyecto. Presentamos un modelo de amenaza formal, reducimos la seguridad a dos supuestos estándar (resistencia a colisiones de SHA-256 e infalsificabilidad EUF-CMA de Ed25519) y demostramos tres teoremas: (T1) evidencia de manipulación de la cadena de hashes, (T2) autenticidad mediante firmas de operador verificadas, y (T3) detectabilidad de reescrituras históricas silenciosas mediante un ancla externa que el adversario no controla.

Executive Summary / Resumen Ejecutivo (ES)

tocsectionExecutive Summary

Para decisores no técnicos. Una página y media.

El problema.

En un conteo electoral disputado, un actor estatal corrupto rara vez ``cambia un número" de forma burda: reescribe datos, retrasa publicaciones, o ciega al observador cortando el acceso y presentando el corte como ``inoperancia". Los sistemas de monitoreo ingenuos registran esto como un fallo cualquiera. El resultado: la manipulación queda como duda, no como prueba.

La tesis.

Centinela no le pide al ciudadano ni al observador internacional que confíe en nadie ---ni en la autoridad, ni en el operador, ni en el autor del software. Entrega una prueba matemática de que los datos capturados no fueron alterados silenciosamente, verificable de forma independiente por cualquiera, en cualquier país, sin permiso privilegiado y a costo cero.

Cómo, en una frase.

Cada captura se encadena criptográficamente con la anterior (SHA-256), se firma con la clave del operador (Ed25519), y la raíz de toda la historia se ancla periódicamente en un registro público externo que el adversario no controla. Reescribir el pasado obliga a romper una función hash, a falsificar una firma, o a divergir visiblemente del ancla externa: las tres son detectables por un tercero.

Qué garantiza y qué no.

Centinela prueba integridad de custodia (lo que se capturó es lo que se sirvió, sin reescritura silenciosa) y no repudio del cegamiento (un corte dirigido deja huella firmada e inmutable). **No** afirma fraude por sí mismo, **no** cuenta votos, **no** reemplaza al tribunal electoral: produce la evidencia forense neutral sobre la que un tribunal, un observador o un perito decide.

Estado y comparación.

A diferencia de OASIS o sistemas tipo Mirador (Guatemala), cuya confianza es institucional (confiar en quien observa), Centinela ofrece confianza verificable sin confiar, heredada del modelo probado de Certificate Transparency (RFC 6962), aplicada por primera vez a custodia electoral en un entorno hostil. El núcleo de seguridad está implementado y probado; el paso pendiente es validación académica independiente y un piloto en condiciones reales ---no más diseño.

Petición.

Validación matemática independiente (referees designados, p. ej. vía UPNFM) y financiamiento de un piloto acotado. El presupuesto solicitado es una fracción mínima del costo de una misión de observación internacional, y cierra una brecha que esas misiones han intentado cerrar sin lograrlo: prueba de no manipulación que no depende de confiar en el árbitro.

Introduction

Electoral disputes in fragile democracies rarely turn on a single falsified tally sheet. They turn on custody: whether the data the public sees today is the same data the authority published yesterday, and whether the observer was able to witness continuously or was quietly blinded. Honduras' contested counts ---which, by institutional inoperancy and corruption, have historically extended for more than a month--- are a worst case: if a protocol survives that environment, it generalizes.

Centinela treats the electoral authority as a potential adversary, not a trusted party. This is a deliberate inversion of the usual model. Most monitoring tools assume the authority is honest and the network is the threat. We assume the authority's published surface, the network path, and a subset of storage may all be adversarial, and ask: what can still be proven to a third party who trusts no one in the system, including the project's own author?

The answer is the Certificate Transparency (CT, RFC 6962 [ref]) construction, repurposed. CT made the certificate authority ---a trusted monopoly--- publicly accountable through an append-only, cryptographically verifiable log that anyone can audit and that misbehavior cannot hide from. Centinela applies the same principle to electoral data custody.

Contributions.

1. A formal threat model for adversarial electoral custody where the publishing authority is untrusted (§§).
2. Security reduced to two standard assumptions; three theorems with proofs (§§--§§).
3. A non-repudiation result for witness blinding: a targeted outage becomes signed, immutable evidence rather than silence (§§).
4. A country-agnostic, zero-cost reference implementation; every claim mapped to verifiable source (Appendix B).

Threat Model

sec:threat

Definition. Authority O: publishes electoral data at a public endpoint. Witness W: an operator running Centinela that captures, hashes, signs, and publishes custody records. Observer V: any third party (citizen, academic, international mission) that verifies, holding no secret and trusting no participant. Anchor T: an external append-only public medium (e.g. a public Git history; optionally OpenTimestamps → Bitcoin) outside the adversary's control.

Definition. A probabilistic polynomial-time adversary that may: (a) fully control O's published content and timing; (b) control network paths between O and W (DNS, TLS interception, reset injection, route blackhole); (c) obtain read/write access to a subset of W's on-disk custody store; (d) attempt to sabotage W's software dependencies (including the cryptographic backend).

Definition. Adv does not possess: (i) the private signing key of at least one honest witness; (ii) write access to the external anchor T. These are the only trust assumptions, and both are operational and externally observable rather than placed in the protocol's author or in the authority.

Remark. The author of Centinela is explicitly inside the adversary's possible reach (the code is open and auditable; there is no phone-home, telemetry, or author-controlled endpoint --- verifiable in Appendix B). The protocol must therefore be secure even if the author is coerced. This is why all verification is reproducible from public data and public source.

Definitions and Assumptions

sec:defs

Let $H:0,1^* \rightarrow 0,1^{256}$ be SHA-256. Let (Sig,Vrf) be Ed25519 with key pair (sk,pk).

Definition. A snapshot s_i is a tuple (c_i, m_i, t_i) where c_i is the captured content (bytes), m_i is canonical metadata (including the source URL and an ISO-8601 UTC timestamp), and t_i is the timestamp string. The canonical serialization $\text{can}(m_i)$ is JSON with sorted keys and fixed separators (deterministic across deployments).

Definition. With $h_0 = \perp$ (empty), define for $i \geq 1$: $h_i = H(h_{i-1} \parallel c_i \parallel \text{can}(m_i) \parallel t_i)$. The chain is $C = \{(s_1, h_1), \dots, (s_n, h_n)\}$. (Reference: `_compute_expected_hash`, `compute_snapshot_hash`.)

Definition. A record r_i stores s_i , h_i , h_{i-1} and an optional block $\sigma_i = \text{Sig}_{sk}(\text{can}(r_i \setminus \sigma))$ together with pk and operator id. `verify_hash_record_signature` recomputes the canonical pre-image and checks Vrf_{pk} .

Definition. $\text{MR}((h_1, \dots, h_n))$ is the SHA-256 Merkle root over the ordered leaf hashes (duplicate-last for odd levels). (Reference: `compute_merkle_root`.)

Definition. At intervals, W commits a checkpoint $ck_j = (\text{MR}_j, n_j, \tau_j)$ to T, where τ_j is an external, adversary-independent timestamp (public Git commit history; optionally OpenTimestamps). T is append-only and publicly readable. (Reference: `append_transparency_checkpoint`, endpoint GET /audit/transparency.)

Assumption. For PPT Adv, $\Pr[(x,y) \leftarrow \text{Adv} : x \neq y \wedge H(x)=H(y)] \leq \text{negl}(\lambda)$.

Assumption. For PPT Adv with a signing oracle for sk, the probability of producing a valid (μ^*, σ^*) with μ^* never queried is $\leq \text{negl}(\lambda)$.

Security Theorems

sec:theorems

Theorem. Under Assumption §, any modification, insertion, deletion, or reordering of a snapshot at position k in C causes h_k to differ from the recomputed value with all but

negligible probability, and the discrepancy propagates to every h_i , $i \geq k$. Consequently an observer recomputing the chain from public data detects the exact break index, and an adversary cannot present an alternative chain with an unchanged head h_n except with probability $\leq \text{negl}(\lambda)$.

Proof. By Definition §, h_k binds h_{k-1} , c_k , $\text{can}(m_k)$ and t_k . Suppose Adv alters $s_k \rightarrow s'_k$ with $s'_k \neq s_k$ yet the stored h_k verifies, i.e. $H(h_{k-1} \parallel c'_k \parallel \text{can}(m'_k) \parallel t'_k) = H(h_{k-1} \parallel c_k \parallel \text{can}(m_k) \parallel t_k)$ with distinct pre-images. This is a SHA-256 collision, contradicting Assumption §. Insertion/deletion/reordering changes the pre-image of the affected position identically. For propagation: h_k feeds h_{k+1} ; to keep h_{k+1} unchanged after h_k changes again requires a collision; inductively this holds to h_n . An honest recomputation (`verify_hashchain_from_snapshots`) therefore stops at the first index where stored $\neq$ recomputed, which is exactly k . To keep h_n fixed while changing any earlier s_k would require a collision at some level, again negligible.

Theorem. Under Assumption §, an adversary without the honest operator's sk cannot produce a record r such that `verify_hash_record_signature(r)=true` for that operator's pk , except with probability $\leq \text{negl}(\lambda)$. Hence every record is classifiable by an observer into exactly one of: authenticated (valid σ), unauthenticated (no σ), or forged/invalid (a σ that fails). Forged and invalid signatures are always reported.

Proof. The verifier recomputes the canonical pre-image $\mu = \text{can}(r \setminus \sigma)$ deterministically and checks $\text{Vrf}_{pk}(\mu, \sigma)$. A successful forgery on a fresh μ is an EUF-CMA break, contradicting Assumption §. Absence of σ is detected structurally (no signature block) and reported as unauthenticated; a present-but-failing σ is reported in `signature_failures`. The three classes are mutually exclusive and exhaustive by construction.

Remark. Per the hostile threat model, the cryptographic backend may be sabotaged (adversary capability (d)). Signing is therefore optional enrichment: a missing or failed signature degrades a record to "unauthenticated but still hash-chained and immutable", and is surfaced to the observer --it never silently invalidates an otherwise hash-valid chain, nor does it crash the month-long capture. T1 (custody integrity) holds independently of T2 (authenticity). This separation is the formal justification for the BaseException-catching design in the reference implementation.

Theorem. Suppose Adv has storage write access and the signing key (the strongest case: it can re-hash and re-sign a fully consistent alternative history C'). Let MR and MR' be the Merkle roots of C and C' . If C' differs from C in any leaf, then $\Pr[\text{MR}' = \text{MR}] \leq \text{negl}(\lambda)$ under Assumption §. Since a prior root was committed to the append-only external anchor T (which Adv cannot rewrite by the trust boundary), any observer comparing the live root against the anchored root detects the divergence with $O(1)$ reads.

Proof. A Merkle root is collision-resistant if its compression function is: distinct leaf multisets yielding equal roots imply a SHA-256 collision at some internal node, contradicting Assumption §. Thus $C \neq C' \Rightarrow \text{MR} \neq \text{MR}'$ w.h.p. The honest checkpoint $ck_j = (\text{MR}_j, n_j, \tau_j)$ resides in T , append-only and outside Adv's write set. The observer fetches the live root via `GET /audit/transparency`, fetches ck_j from T , and compares. Equality of a rewritten history with the anchored root would again require a collision. Therefore silent rewrite is detectable; the adversary's only alternatives are to (i) not rewrite, or (ii) rewrite and diverge visibly from T , which is exactly the detection event.

Corollary. If k independent witnesses publish roots for the same authority data, any pairwise root mismatch localizes tampering or divergence without any witness being individually trusted: agreement is cryptographic, not reputational.

Non-Repudiation of Witness Blinding

sec:outage

A subtle attack is not to alter data but to prevent its capture and present the gap as the authority's own inoperancy.

Definition. On a fetch failure, a bounded, side-effect-free diagnosis classifies the cause via probes (DNS resolution vs. expected, TCP reachability, TLS fingerprint vs. pinned) into authority-inoperancy vs. targeted-interference signals, and records the verdict, evidence signals, and exact failure mode as a signed, append-only event in the same tamper-evident stream as custody. (Reference: `diagnose_and_record`, endpoint `GET /audit/degradation`.)

Lemma. Under Assumptions §--§, an adversary executing a targeted cut (DNS redirection, TLS MITM, reset injection, route blackhole) cannot cause the witness to record nothing: the failure produces a degradation event whose interference signals (unexpected resolved IPs, presented-vs-pinned TLS fingerprint mismatch, exact failure mode) are appended and (best-effort) signed. Deleting that event is a chain modification detectable by Theorem §; its signals are conservative (they never assert fraud) but are non-repudiable.

Proof. The diagnosis path is invoked unconditionally on fetch failure and is bounded (hard timeout, capped attempts) so it cannot wedge the capture loop. The event is written with the same fsync-durable, append-only discipline as custody records and is included in the hash chain; therefore Theorem § applies to its removal. Signal collection probes only the exact already-contacted host:port (no redirects, no attacker-influenced addresses), so the recorded signals reflect the adversary's own interference. Signing is best-effort (Remark after Theorem §); even unsigned, the event remains immutable by T1.

Remark. Centinela classifies and records; it does not adjudicate. ``Targeted interference observed" is an evidentiary signal for a human/institutional process, not a fraud verdict. This conservatism is what makes the output admissible to neutral observers.

Comparison with Existing Systems

sec:comparison

lcccc@	Centinela	CT (RFC 6962)	Mirador-type	Authority TREP/PREP
Trust model	verify, no trust	verify, no trust	institutional	institutional
Authority adversary =	yes	n/a (CA)	no	no
Hash-chained custody	yes	yes (log)	no	partial
External anchor	yes	yes (STH)	no	no
Blinding non-repudiation	yes	no	no	no
3rd-party reproducible	yes	yes	limited	limited
Operating cost	zero	infra	funded	state
Country-agnostic	yes	yes	per-deployment	per-state

Table. Centinela inherits CT's ``verify without trusting" guarantee and extends it with authority-as-adversary custody and blinding non-repudiation. Institutional observation systems provide value but their trust is reputational, not cryptographically third-party reproducible.

The closest intellectual ancestor is Certificate Transparency: a log that made a trusted monopoly (the CA) publicly accountable. Centinela's novelty is the authority-as-adversary

threat model applied to electoral custody, plus Lemma § (blinding becomes evidence), which has no analogue in CT or in institutional electoral observation.

Limitations and Future Work

sec:limits

1. **Custody, not counting.** Centinela proves the captured data was not silently rewritten; it does not verify the data is politically correct. Statistical anomaly analysis (Benford, distributional shifts) is complementary and out of scope for the formal core of v1.0.
2. **Capture-time trust.** Theorems bind everything from the first capture forward. A datum the authority never published, or published falsely from inception, is outside custody guarantees ---this is the correct, honest boundary, addressed operationally by multiple independent witnesses (Corollary 1) and by the degradation log.
3. **Operator key hygiene.** T2 assumes at least one honest, uncompromised signing key. Key management is operational; the protocol degrades gracefully to T1-only (Remark after T2) when keys are absent or sabotaged.
4. **Anchor liveness.** T3 requires the external anchor to be append-only and reachable by observers. Public Git history satisfies this at zero cost; Bitcoin anchoring via OpenTimestamps is an optional strengthening.
5. **Deployment risk.** The hostile-environment endurance (month-long count, sustained observer load, sabotaged dependencies) is engineered and tested in isolation but not yet validated in a real national contest. This is the explicit, honest gap and the purpose of the requested pilot.
6. **Validation status.** The formal model herein is pen-and-paper rigorous (IACR style, reduced to standard assumptions). Independent academic review (e.g. UPNFM-appointed referees) is the intended next step; machine-checked proofs are deliberately out of scope as they add cost without increasing institutional credibility.

Conclusion

Centinela turns a contested electoral count from a contest of whom to believe into a contest of verifiable mathematics. It does not ask the world to trust Honduras' authority, the witness operator, or the project's author. It provides a third party, anywhere, with the ability to recompute and confirm ---or refute--- custody integrity from public data and public source, at zero cost, and to read an immutable, signed record of whether the witness was blinded. The construction is the proven Certificate Transparency lineage, extended to the case where the publisher itself is the adversary. The cryptographic core is implemented and tested; what remains is independent validation and a real-world pilot ---not further design.

Notation

H: SHA-256. (Sig,Vrf): Ed25519. $\parallel$: byte concatenation. can($\cdot$): canonical deterministic JSON. MR: SHA-256 Merkle root. $\text{negl}(\lambda)$: negligible in the security parameter.

Mapping Claims to the Reference Implementation

app:map

All references are to branch dev-v9. Each formal object is realized and independently verifiable at:

- **Def. § (chained hash):** `src/centinel/core/custody.py::_compute_expected_hash`; `src/centinel/hasher.py::compute_snapshot_hash`.
- **Thm. § (tamper-evidence):** `custody.py::verify_chain`, `hasher.py::verify_hashchain_from_snapshots` (stops at exact break index; streaming, payload-free metadata scan for month-long endurance).
- **Thm. § (authenticity):** `custody.py::verify_hash_record_signature`; `ChainVerificationResult.signature_failures`; endpoint `GET /audit/chain/verify`.
- **Thm. § (rewrite detection):** `core/transparency.py::compute_merkle_root`, `append_transparency_checkpoint`; endpoint `GET /audit/transparency`.
- **Lemma § (blinding non-repudiation):** `core/connectivity.py::diagnose_and_record`, `read_degradation_log`; endpoint `GET /audit/degradation`.
- **Author-exposure boundary:** no phone-home, telemetry, or author endpoint; identifiers are pseudonymous; alerts are operator opt-in. Auditable across the source tree (absence of outbound author-controlled calls).

Verification Recipe for an Independent Observer

1. Clone the public source at the audited revision; read `custody.py`, `hasher.py`, `transparency.py`, `connectivity.py`.
2. Fetch `GET /audit/chain/verify`; recompute the chain locally from published snapshots; confirm valid and inspect `signature_failures`.
3. Fetch `GET /audit/transparency`; compare the live Merkle root against the externally anchored checkpoint (public Git history / OpenTimestamps).
4. Fetch `GET /audit/degradation`; inspect the immutable timeline of interference vs. inoperancy signals.
5. Repeat against independent mirrors; cryptographic agreement, not reputation, is the trust basis (Corollary 1).

References

- B. Laurie, A. Langley, E. Kasper. Certificate Transparency. RFC 6962, IETF, 2013.
- R. C. Merkle. A Digital Signature Based on a Conventional Encryption Function. CRYPTO 1987.
- D. J. Bernstein et al. High-speed high-security signatures. J. Cryptographic Engineering, 2012.
- NIST. FIPS 180-4: Secure Hash Standard. 2015.
- OpenTimestamps. Scalable, trustless timestamping on the Bitcoin blockchain. <https://opentimestamps.org>.